

VULNERABILITY ASSESSMENT REPORT

Nmap & Nessus — Target: Metasploitable

Data	07 Maggio 2026
Analista	Giuseppe
Target	Metasploitable 2 — 192.168.0.6
Ambiente	VirtualBox — Rete locale 192.168.0.0/24
Strumenti	Nmap 7.98 / Nessus Essentials
Classificazione	Uso didattico — Ambiente di laboratorio controllato

1. Obiettivo

L'obiettivo di questa attività è eseguire un vulnerability assessment completo su una macchina Metasploitable 2 in ambiente di laboratorio controllato, utilizzando strumenti standard del settore della sicurezza informatica.

Le attività svolte comprendono:

- Scansione della rete locale per identificare host attivi
- Identificazione delle porte aperte e dei servizi in esecuzione sul target
- Rilevamento delle versioni dei servizi tramite Nmap
- Scansione automatizzata delle vulnerabilità con Nessus Essentials
- Analisi e classificazione dei risultati per livello di rischio

2. Metodologia

La valutazione è stata condotta seguendo un approccio a tre fasi progressivo:

Fase	Strumento	Descrizione
1	Nmap -sn	Host discovery — ping scan sulla subnet
2	Nmap -sS / -sV	Port scan e service version detection sul target
3	Nessus Essentials	Vulnerability scan automatizzato e analisi dei risultati

3. Fase 1 — Host Discovery con Nmap

3.1 Comando eseguito

```
nmap -sn 192.168.0.0/24
```

3.2 Risultati — Host attivi rilevati

IP Address	Hostname	MAC / Vendor
192.168.0.1	skyhub4.Home	SKY UK Limited
192.168.0.6	— (TARGET)	Oracle VirtualBox virtual NIC
192.168.0.47	—	Unknown
192.168.0.143	TP10.Home	TP-Link Systems
192.168.0.175	—	Samsung Electronics
192.168.0.194	—	Amazon Technologies
192.168.0.222	firestick-f090...Home	Amazon Technologies
192.168.0.226	—	Unknown
192.168.0.234	Giuseppe.Home	Micro-Star Intl
192.168.0.248	xiaomi_vacuum_c102gl.Home	Dreame Technology
192.168.0.239	kali.Home	— (Attacker Machine)

Totale host rilevati: 11 su 256 IP scansionati. Il target Metasploitable è stato identificato all'indirizzo 192.168.0.6 con MAC Oracle VirtualBox.

4. Fase 2 — Port Scan e Service Detection

4.1 Comandi eseguiti

```
sudo nmap -sS 192.168.0.6
```

```
sudo nmap -sV 192.168.0.6
```

4.2 Servizi identificati

Porta/TCP	Stato	Servizio	Versione rilevata
21	OPEN	FTP	vsftpd 2.3.4
22	OPEN	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23	OPEN	Telnet	Linux telnetd
25	OPEN	SMTP	Postfix smtpd
53	OPEN	DNS	ISC BIND 9.4.2
80	OPEN	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
111	OPEN	rpcbind	2 (RPC #100000)
139/445	OPEN	Samba SMB	Samba smbd 3.X - 4.X (WORKGROUP)
512-514	OPEN	exec/login/shell	rexec, rlogin, tcpwrapped
1099	OPEN	Java-RMI	GNU Classpath grmiregistry
1524	OPEN	Bindshell	Metasploitable root shell
2049	OPEN	NFS	2-4 (RPC #100003)
2121	OPEN	FTP (alt)	ProFTPD 1.3.1
3306	OPEN	MySQL	MySQL 5.0.51a-3ubuntu5

5432	OPEN	PostgreSQL	PostgreSQL DB 8.3.0 - 8.3.7
5900	OPEN	VNC	VNC protocol 3.3
6000	OPEN	X11	(access denied)
6667	OPEN	IRC	UnrealIRCd
8009	OPEN	AJP13	Apache Jserv Protocol v1.3
8180	OPEN	HTTP (alt)	Apache Tomcat/Coyote JSP 1.1

OS Detection: Unix/Linux — CPE: cpe:/o:linux:linux_kernel

5. Fase 3 — Vulnerability Scan con Nessus Essentials

5.1 Configurazione della scansione

Policy	Basic Network Scan
Target	192.168.0.6
Scanner	Local Scanner
Severity Base	CVSS v3.0
Totale vulnerabilita'	33

5.2 Riepilogo per severita'

Severita'	N. Vulnerabilita'	CVSS Max	Rischio
CRITICAL	3	10.0	Accesso remoto immediato possibile
HIGH	2	7.5	Servizi non sicuri esposti
MIXED	5	—	Vulnerabilita' multiple su piu' servizi
LOW	1	2.1	Bassa priorita'
INFO	22+	—	Informazioni e rilevamenti non critici

5.3 Analisi delle vulnerabilita' CRITICAL

Vulnerabilita'	CVSS	Descrizione e impatto
UnrealIRCd Backdoor Detection	10.0	Il server IRC sulla porta 6667 contiene una backdoor hardcoded che permette esecuzione remota di comandi arbitrari senza autenticazione. Accesso root immediato.
VNC Server 'password' Password	10.0	La password VNC configurata e' 'password'. Un attaccante puo' ottenere accesso completo al desktop remoto senza alcuna barriera di sicurezza.
Bind Shell Backdoor Detection	9.8	Una shell root e' gia' in ascolto sulla porta 1524. Qualsiasi connessione a questa porta fornisce accesso root diretto senza autenticazione.

5.4 Analisi delle vulnerabilita' HIGH

Vulnerabilita'	CVSS	Descrizione e impatto
rsh Service Detection	7.5	Il servizio Remote Shell (rsh) sulla porta 514 trasmette dati in chiaro e non implementa autenticazione robusta. Facilmente sfruttabile per accesso laterale.
Samba Badlock Vulnerability	7.5	La versione di Samba e' affetta dalla vulnerabilita' Badlock (CVE-2016-2118), che consente attacchi Man-in-the-Middle sulle sessioni SMB/DCE-RPC.

5.5 Altri rischi rilevati (MIXED)

- ISC Bind 9.4.2 — 5 vulnerabilita' multiple: versione obsoleta del server DNS soggetta a diverse CVE note
- HTTP / Apache 2.2.8 — 3 vulnerabilita': versione non aggiornata, header informativi esposti
- Apache Tomcat — 2 vulnerabilita': pannello di amministrazione accessibile con credenziali di default
- SMB Multiple Issues — 2 vulnerabilita': condivisioni di rete aperte, enumerazione utenti
- ICMP Timestamp — CVSS 2.1: disclosure della data/ora del sistema remoto

6. Conclusioni e Valutazione del Rischio

La macchina Metasploitable 2 presenta un livello di rischio CRITICO. L'analisi combinata con Nmap e Nessus ha evidenziato una superficie di attacco estremamente ampia, con molteplici vettori che permettono accesso root senza autenticazione.

Aspetto	Valutazione
Superficie di attacco	MOLTO AMPIA — 20+ servizi esposti
Facilita' di compromissione	IMMEDIATA — 3 vettori critical senza autenticazione
Aggiornamenti software	ASSENTI — Tutte le versioni sono obsolete e vulnerabili
Configurazione sicurezza	INADEGUATA — Backdoor, password deboli, servizi insicuri
Scopo in ambiente reale	Solo didattico — Non esporre mai in rete pubblica

Nota: Tutte le attivita' descritte in questo report sono state eseguite in un ambiente di laboratorio isolato e controllato, su sistemi di proprieta' personale, esclusivamente a scopo didattico.